Prática AES — confusão, difusão e efeito avalanche

DCC075 – Segurança em Sistemas Computacionais · UFJF · Lucas Gonçalves Rocha · Matrícula 202265187C · Individual · Outubro de 2026

Resultados medidos (`python3 aluno.py`)

Rodadas	1	2	3	4	5	6	7	8	9	10
Com MixColumns (bits/128)	4,0	16,0	64,0	64,0	64,0	64,1	64,0	64,1	64,1	64,1
Com MixColumns (%)	3,1	12,5	50,0	50,0	50,0	50,1	50,0	50,1	50,1	50,1
Sem MixColumns (%)	–	3,1	–	3,1	–	3,2	–	–	–	3,2

Média sobre 1500 amostras aleatórias por ponto, invertendo 1 bit do texto claro. AES completo (Parte 1): 64,1/128 (50,1%) para 1 bit no texto e 64,0/128 (50,0%) para 1 bit na chave. Núcleo validado com o vetor do FIPS-197.

Parágrafo técnico

Confusão é tornar a relação entre a chave e o ciphertext complexa e não linear, de modo que conhecer pares texto/cifrado não permita montar equações simples para a chave; no AES ela é feita pela **S-box** (*SubBytes*), a única etapa não linear da rodada. **Difusão** é fazer cada bit de entrada influenciar muitos bits de saída; no AES ela vem de ***ShiftRows***, que desloca os bytes entre colunas, e de ***MixColumns***, que mistura os 4 bytes de cada coluna, de modo que alterar 1 byte altera a coluna inteira. Os dados mostram essa propagação de forma exata. Com 1 rodada, a diferença ocupa 1 byte (≈ 4 bits, 3,1%), pois a última rodada não tem MixColumns; com 2, o MixColumns da 1ª rodada a espalha por uma coluna de 4 bytes (≈ 16 bits, 12,5%); com 3, o ShiftRows leva esses 4 bytes a 4 colunas e o MixColumns atinge os 16 bytes, e a avalanche **satura em ~50% já na 3ª rodada**, permanecendo nesse valor até a 10ª. Sem MixColumns, a diferença fica presa em um único byte (≈ 4 bits, ~3%) com qualquer número de rodadas, porque SubBytes age byte a byte e ShiftRows apenas muda o byte de lugar: a S-box fornece confusão, mas sem difusão as rodadas extras não espalham nada, e cada byte poderia ser atacado isoladamente.

Parágrafo crítico

Se a avalanche já é completa na 3ª rodada, as outras 7 rodadas do AES-128 não existem para "espalhar mais", e sim como **margem de segurança**. Atingir 50% de bits alterados é condição necessária, mas não suficiente: a criptoanálise diferencial, linear, de diferenciais impossíveis e *meet-in-the-middle* explora estruturas estatísticas que sobrevivem a algumas rodadas mesmo com avalanche completa. Há ataques publicados a versões reduzidas do AES-128, como os de diferenciais impossíveis em 7 rodadas [1], cujos custos, ainda assim, estão muito além do praticável. Para as 10 rodadas, o melhor resultado conhecido, a criptoanálise *biclique* [2], recupera a chave com cerca de $2^{126,1}$ operações, contra 2^{128} da força bruta: um ganho de apenas ~4 vezes, sem nenhum efeito prático. Projetar com margem é, portanto, uma decisão de engenharia de segurança análoga ao coeficiente de segurança de uma ponte: o projetista não sabe quais ataques serão descobertos nas próximas décadas, e cada avanço da criptoanálise costuma "ganhar" uma ou duas rodadas. Uma cifra com o número mínimo de rodadas que resiste aos ataques conhecidos hoje poderia ser quebrada pelo próximo artigo; com 10 rodadas, o AES absorveu mais de vinte anos de pesquisa sem perder a segurança prática. O custo dessa margem — algumas rodadas a mais de processamento, amenizado por instruções dedicadas como AES-NI — é pequeno diante do custo de ter que substituir um padrão quebrado.

Referências

[1] H. Mala, M. Dakhilalian, V. Rijmen, M. Modarres-Hashemi. *Improved Impossible Differential Cryptanalysis of 7-Round AES-128.* INDOCRYPT 2010, LNCS, pp. 282–291.

[2] A. Bogdanov, D. Khovratovich, C. Rechberger. *Biclique Cryptanalysis of the Full AES.* ASIACRYPT 2011. Cryptology ePrint Archive 2011/449.

[3] NIST. *FIPS-197: Advanced Encryption Standard (AES)*, 2001.